

Đề bài: Recipe Web Application (Fullstack)

Tổng quan: Xây dựng một ứng dụng web đặt món (recipe app) với hai nhóm người dùng — **User** và **Admin**. Frontend là SPA, backend là **NestJS + MongoDB**, giao tiếp qua **RESTful API** và **Server-Sent Events** cho thông báo realtime.

Quy ước mã yêu cầu

Tiền tố	Phạm vi
US-xx	Chức năng phía User
AD-xx	Chức năng phía Admin
FE-xx	Yêu cầu kỹ thuật Frontend
BE-xx	Yêu cầu kỹ thuật Backend (NestJS)

1. Vai trò & phân quyền

Vai trò	Mô tả
Guest	Chưa đăng nhập. Chỉ truy cập được trang xác thực (sign in / sign up / quên mật khẩu).
User	Đã đăng nhập. Xem món, tìm kiếm, đặt món, quản lý đơn của mình, quản lý profile.
Admin	Kế thừa toàn bộ quyền và trang của User, ngoại trừ quyền tự đặt món . Bổ sung các trang quản trị.

2. Chức năng phía User

2.1. Xác thực

Mã	Yêu cầu
US-01	Sign Up / Sign In / Quên mật khẩu gộp chung trong 1 trang (chuyển đổi giữa các mode, không tách route riêng biệt).
US-02	Phương thức xác thực: email + password .
US-03	Luồng quên mật khẩu: gửi yêu cầu → xác thực → đặt lại mật khẩu mới.

2.2. Duyệt & tìm kiếm món ăn

Mã	Yêu cầu
US-04	Trang danh sách món ăn trong app.
US-05	Tìm kiếm món ăn (xem ràng buộc kỹ thuật tại FE-06).
US-06	Trang chi tiết món ăn .

2.3. Đặt món & theo dõi đơn

Mã	Yêu cầu
US-07	Đặt khẩu phần món (chọn số khẩu phần khi đặt).
US-08	Trang theo dõi các đơn đã đặt của chính user đó.
US-09	Chỉnh sửa đơn đã đặt.
US-10	Hủy đơn đã đặt.
US-11	Xem trạng thái đơn : Đang làm / Hoàn thành / Bị hủy . Nếu bị hủy, hiển thị lý do hủy do Admin nhập.

2.4. Tài khoản

Mã	Yêu cầu
US-12	Chỉnh sửa profile trong 1 trang duy nhất: name , email , đổi mật khẩu , avatar .
US-13	Xoá tài khoản .
US-14	Sau khi xoá, nếu đăng ký lại bằng chính email đó thì phải tạo ra một profile hoàn toàn mới — không khôi phục dữ liệu, đơn hàng hay thông tin cũ.

3. Chức năng phía Admin

AD-00 — Nguyên tắc kế thừa: Admin truy cập được **mọi trang** và dùng được **mọi tính năng** của User, **trừ** việc tự đặt món (**US-07**) bị vô hiệu hoá với Admin).

3.1. Quản trị đơn đặt món

Mã	Yêu cầu
AD-01	Trang quản trị xem danh sách toàn bộ đơn đặt món trong hệ thống.
AD-02	Đánh dấu trạng thái đơn: Đang làm , Hoàn thành , Bị huỷ .
AD-03	Khi chọn Bị huỷ , bắt buộc nhập lý do huỷ ; lý do này hiển thị cho user tại US-11 .
AD-04	Dashboard thống kê với biểu đồ.

3.2. Quản trị quản trị viên

Mã	Yêu cầu
AD-05	Trang quản lý danh sách quản trị viên trong ứng dụng.
AD-06	Cấp quyền admin cho người dùng mà admin chỉ định.
AD-07	Thu hồi quyền admin .

3.3. Quản trị Recipe

Mã	Yêu cầu
AD-08	Trang quản trị recipe riêng biệt cho phép Create / Edit / Delete món ăn.
AD-09	 Trang này phải tách bạch hoàn toàn với trang xem món / đặt món phía user — không được gộp chung hay tái sử dụng lẫn lộn giao diện.

4. Yêu cầu kỹ thuật Frontend

4.1. Bảo mật & điều hướng

Mã	Yêu cầu
FE-01	Guard chống directory traversal attack .
FE-02	Khi chưa đăng nhập , chặn truy cập vào mọi trang ngoại trừ Sign In / Sign Up.
FE-03	Khi phiên đăng nhập hết hạn, tự động redirect người dùng về trang login .

4.2. Thiết kế giao diện

Mã	Yêu cầu
FE-04	Áp dụng skill frontend-design của Claude kết hợp với file GETDESIGN.MD .
FE-05	Tự lựa chọn design theme và bố cục thiết kế theo sáng tạo của người thực hiện.

4.3. Tìm kiếm

Mã	Yêu cầu
FE-06	Search phải gọi qua RESTful API , không filter phía client.
FE-06.1	Có debounce cho input tìm kiếm.
FE-06.2	Chống khoảng trắng — không gửi request khi keyword chỉ chứa space / trim ra rỗng.
FE-06.3	Không search ở ký tự đầu tiên — chỉ gửi request khi keyword đạt độ dài tối thiểu.
FE-06.4	Chống trùng keyword — nếu keyword sau khi nhập giống hệt keyword trước đó, không gửi request search.
FE-07	Các trang quản trị cũng phải có search tương ứng: search thành viên quản trị , search recipe .

4.4. Trải nghiệm người dùng

Mã	Yêu cầu
FE-08	Responsive đầy đủ trên mobile / tablet / desktop.
FE-09	Có loading state cho mọi thao tác bất đồng bộ.
FE-10	Có error state với thông điệp thân thiện với người dùng (UI/UX++).
FE-11	Hỗ trợ lazy loading .
FE-12	Upload ảnh : avatar của user và ảnh recipe khi create/edit.
FE-13	Confirmation dialog trước mỗi chức năng quan trọng cần user xác nhận lại (xóa tài khoản, hủy đơn, xóa recipe, thu hồi quyền admin, ...).

4.5. Tích hợp

Mã	Yêu cầu
FE-14	Toàn bộ tính năng trong app phải được chuyển thành các RESTful API kết nối tới server NestJS.

5. Yêu cầu kỹ thuật Backend (NestJS)

5.1. Bảo mật & xác thực

Mã	Yêu cầu
BE-01	Authentication / Authorization .
BE-02	Encryption and Hashing .
BE-03	Custom JWT — tự triển khai, không phụ thuộc hoàn toàn vào lib có sẵn.
BE-04	Verification token .
BE-05	Refresh token .
BE-06	Invoke / thu hồi token .
BE-07	CORS .

5.2. Kiến trúc NestJS

Mã	Yêu cầu
BE-08	Modules.
BE-09	Controllers.
BE-10	Providers.
BE-11	Middleware.
BE-12	Guards.
BE-13	Pipes.
BE-14	Exception Filters.
BE-15	Validation.
BE-16	Configuration.

5.3. Dữ liệu & realtime

Mã	Yêu cầu
BE-17	MongoDB.
BE-18	Server-Sent Events (SSE) để gửi thông báo về đơn đặt khi: (a) recipe/đơn thay đổi status, (b) đơn được tạo mới từ phía user.

6. Ma trận quyền truy cập

Chức năng	Guest	User	Admin
Sign in / Sign up / Quên mật khẩu	✓	—	—
Xem danh sách & chi tiết món	✗	✓	✓
Tìm kiếm món	✗	✓	✓
Đặt khẩu phần món	✗	✓	✗
Theo dõi / sửa / huỷ đơn của mình	✗	✓	✓ (đơn của chính mình, nếu có)
Edit profile / đổi mật khẩu / avatar	✗	✓	✓
Xoá tài khoản	✗	✓	✓
Quản trị đơn + đổi status + lý do huỷ	✗	✗	✓
Dashboard thống kê	✗	✗	✓
Quản trị & phân quyền admin	✗	✗	✓
CRUD Recipe (trang riêng)	✗	✗	✓

7. Các điểm cần làm rõ trước khi triển khai

- Luồng quên mật khẩu** ((US-03)): dùng link reset qua email hay OTP? Thời hạn hiệu lực của token là bao lâu?
- Đổi email trong profile** ((US-12)): có cần verify lại email mới không?
- Xoá tài khoản** ((US-13), (US-14)): xoá cứng hay ẩn danh hoá? Các đơn hàng cũ của user đã xoá còn hiển thị trong trang quản trị của admin không?
- Sửa đơn** ((US-09)): chỉ được sửa khi đơn ở trạng thái nào? (ví dụ: chỉ khi chưa chuyển sang **Đang làm**)
- Đặt khẩu phần** ((US-07)): có giới hạn số khẩu phần tối đa? Có cần thời gian nhận món / ghi chú kèm theo?
- Dashboard** ((AD-04)): cần thống kê những chỉ số cụ thể nào? (đơn theo trạng thái, món được đặt nhiều nhất, đơn theo thời gian, ...)
- Phân quyền admin** ((AD-06), (AD-07)): có khái niệm Super Admin không? Admin có tự thu hồi quyền của chính mình / của admin khác được không?
- FE-01 — chống directory traversal**: cụ thể hoá phạm vi (sanitize route param, chặn path lạ, hay chủ yếu ở phía API upload/serve file?).
- GETDESIGN.MD**: cần cung cấp file này để áp dụng đúng hướng dẫn thiết kế.
- Framework frontend**: chưa được chỉ định trong đề (React / Angular / Vue?) — cần chốt để làm rõ cách hiện thực lazy loading và route guard.

11. **Lưu trữ ảnh** (**FE-12**, **BE-17**): lưu local trên server, GridFS, hay dịch vụ ngoài (S3/Cloudinary)?